RBI ecosystem requirements → coverage matrix

Rendered 2026-09-20 19:15 UTC from `docs/pilot/RBI_REQUIREMENTS_COVERAGE.md`
commit `d64b937` on `claude/aip-security-architecture-audit-zpf9b3` (source matches this commit)

EXISTS	DONE	PARTIAL	INTEGRATE	BUILD
26	**8**	**6**	**1**	**1**

Counts cover the 42 requirements carrying a disposition. **EXISTS**, **BUILD** and **INTEGRATE** are the source document's own words, defined below. **DONE** marks a row the source records as delivered against this roadmap; **PARTIAL** marks a row claiming both a closed and an open half (for example “DONE (mechanism) / INTEGRATE (placement)”), counted as open rather than closed so the tally cannot overstate readiness. Section G rows name an owner instead of a disposition and are excluded.

How to read a disposition

Status: normative for the roadmap, September 2026. Every requirement an agent deployment inside an RBI-regulated entity must meet, drawn from `RBI_AGENT_RISK_MAP.md`, with one of four dispositions:

- **EXISTS** — code and a test that exercises it, named.
- **BUILD** — inside the accountability domain; roadmap item and acceptance test named. Not shipped until the test passes.
- **INTEGRATE** — the RE's or a partner's system supplies it; we supply the evidence it consumes or the interface it calls.
- **OUT OF SCOPE** — a different discipline with a named owner. Claiming it would be false and RBI would find it.

"Every solution the ecosystem requires" is honest only in this form: the accountability and evidence domain covered completely, and everything else attributed to its owner. A vendor that claims all four columns as EXISTS is the vendor RBI's own FREE-AI report warns REs about. **A disposition is not a proof.** `EXISTS` and `DONE` in this matrix mean *code and a test that exercises it, named*. They do **not** mean the requirement is solved in an institution. What each test actually establishes — and the three structural limits no further testing inside this repository removes — is in `WHAT_THE_TESTS_PROVE.md` beside this file. Read that before quoting any row here to a supervisor. Its short form: nothing in this repository has run on a regulated entity's hardware; no agent doing an institution's real work has been observed (the *framework* is now real and third-party, the workload is not); and every attack in the ledger is one we thought of, except the Phase 4 coverage map, which is stated against an external corpus (Atomic Red Team / MITRE ATT&CK) and marks 6 of 20 techniques not covered. **PDF.** `RBI_REQUIREMENTS_COVERAGE.pdf` beside this file is a **build product of this markdown**, not a separately maintained document. Rebuild it with `python3 tools/render_coverage_pdf.py` after changing anything here. Its cover records the commit it was rendered from and whether this file had been modified since — a readiness brief that has drifted from its source is worse than none, because a reader trusts the artefact in front of them.

A. Authority and mandate (who may do what)

A1 Authorization adjudicated outside the agent, signed before the act

EXISTS

INSTRUMENT
FREE-AI accountability; IMF "verifiable mandates"

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-authorize::DecisionPoint::adjudicate`; `tests/adversarial.rs`

A2 Delegation attenuates only (scope, expiry, depth); issuer must hold the parent

EXISTS

INSTRUMENT
IT Outsourcing "cannot outsource accountability"; MRM third-party

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-core::delegation::verify_delegation_chain`; P0-2 tests

A3 Self-issued authority refused

EXISTS

INSTRUMENT
FREE-AI accountability

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
Decision point refuses it; `verify_packet` now does too when the verifier sets `independent_authority_required` (`aip-verify --require-independent-authority`). Both spellings are caught (declared principal, and the root token's issuer). Default unchanged, and a self-issued pass carries a note in `AUTHORITY_CHAIN`'s detail saying independence was not established. Tests: 3 in `aip-protocol`, 2 through the CLI

A4 Authority over named resources, not only actions

EXISTS

INSTRUMENT
MRM "agent-level authority matrix"; Digit critique

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-registry` (signed registry, `res:<id>` grants inside the attenuating scope) + `aip-authorize::resource` (`ResourcePolicy`; `DestinationUnregistered` / `ResourceNotGranted`); `aip-authorize/tests/resources.rs` (11). Executed anyway → `UNATTRIBUTED_EFFECT` as before

A5 Mandate carries transaction parameters (amount, beneficiary) without observer payload access

EXISTS

INSTRUMENT
NPCI UAP; fraud-liability burden of proof

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-authorize::tool_invoke_parameters` seals `(tool_id, params_commitment)` into the expectation's parameter digest (`ghost.tool.invoke.v1`); the institution's tool gateway countersigns what it received (`aip-airi::ToolReceipt`, third signer, refused under the agent's key); `aip-airi::compare_tool_boundary` names a mismatch `ReceiptDoesNotMatchAuthorization` as arithmetic over the two signed documents. Plaintext arguments enter no signed document (`tests/tool_boundary.rs`, 12). The kernel reconciler returns `ACTION_EVIDENCE_UNAVAILABLE` for this class, never a match or a mismatch; the finding sits beside the verdict (same posture as `aip-approval`), and wiring it into the engine's accusation path is gated per ADR-016

A6 Revocation reaches verification, tenant-scoped

EXISTS

INSTRUMENT
IT Governance access control

DISPOSITION
EXISTS (service)

WHERE / ACCEPTANCE
`aip-service/tests/revocation_scope.rs`

A7 Revocation distributed to offline verifiers with freshness

EXISTS

INSTRUMENT
IT Governance non-repudiation

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip_protocol::RevocationList` (signed, sequenced, `issued_at`/`valid_until`, sorted unique entries; AIP_SPEC §4.4), consumed by `aip-verify --revocations --trust-revocation-issuer`. An expired or unanchored list leaves `REVOCATION` NOT EVALUATED with the reason; a hit fails whatever the freshness. The prior vacuous pass on an empty set is gone. Tests: 7 in `aip-protocol`, 6 in the rule, 5 through the CLI

B. Independent observation (what actually executed)

B1 Execution observed from the kernel, not from the agent

EXISTS

INSTRUMENT
IT Governance audit trail; FREE-AI

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
perf tracepoints + connector, `aip-observe`; `ghost-demo/tests/live_*`

B2 Process identity by content hash and instance, not PID or path

EXISTS

INSTRUMENT
IT Governance forensics

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`ExecutionBinding`; `live.rs` scenario D

B3 Container / namespace identity in the binding

DONE

INSTRUMENT
same

DISPOSITION
DONE (both sides)

WHERE / ACCEPTANCE
`ExecutionBinding` v2 carries `ContainerIdentity` (pid/mnt/net namespace inodes as identity; cgroup v2 id as recorded context, since a cgroup-v1 host has none and a cgroup move is not a change of workload). `compare_execution` distinguishes *different container* from *one side did not record one*, so a blind collector cannot manufacture a divergence. `aip-core` reads the namespaces from `/proc/<pid>/ns/*`. Tests: 12 in `aip-types`, 3 live in `aip-core`. **The observer asserts it independently too** (protocol 11): `ObservedProcess.container` is the placement as the *observer* read it, from `/proc/<pid>/ns/*`, on both the polled and pidfd-anchored paths. It is inside the attested bytes — so what the observer saw, including that it saw nothing, is signed — and deliberately **not** in `ObservedProcess::identity_bytes`, because an observer that cannot read the namespaces would otherwise produce a different identity digest for the same process and manufacture a divergence out of a read failure. `ObservedProcess::compare_container` answers `ContainerNotComparable` for that case instead, mirroring `compare_execution` so both halves of a reconciliation answer the same question the same way. One canonical encoder (`aip_types::put_container`) serves both sides, so the two cannot drift. Tests: 12 in `aip-types`, 3 live in `aip-core`, 10 in `aip-observe/tests/container_identity.rs` including a live reading of this host's own namespaces

B4 Evidence key off the observed host

EXISTS

INSTRUMENT
IT Outsourcing; CERT-In evidence integrity

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-collector` wrapped custodian; `tests/e2e.rs`

B5 Blinded observer says so, never "nothing happened" — EXISTS

INSTRUMENT
FREE-AI safety; non-repudiation

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`IntegrityUnknown` across the split; ledger OI-01..OI-12

B6 Gate-independent coverage for non-occurrence claims — EXISTS

INSTRUMENT
non-repudiation

DISPOSITION
EXISTS in pilot

WHERE / ACCEPTANCE
connector in `aip-probe`; `covers_process_lifecycle`

B7 File and wire evidence in the pilot probe — DONE

INSTRUMENT
forensics

DISPOSITION
DONE

WHERE / ACCEPTANCE
`aip-probe` drives both. `fanotify` (`CAP_SYS_ADMIN`) marks the mount holding `AIP_PROBE_FANOTIFY_PATH` for `FAN_CLOSE_WRITE`, binding the acting instance through a pidfd **the kernel** made from the event's own process reference; the path is required, because `FAN_MARK_MOUNT` makes it the choice of how much of the host is watched. `afpacket` (`CAP_NET_RAW`) records TCP/IP **headers only** — no payload byte copied, hashed or kept (I23) — and never binds a segment to an instance, because the device layer knows no task. Both are gate-independent: neither reaches the probe via a perf tracepoint, so neither owes or is asked for an integrity report. A requested sensor that cannot open is a startup error, never a silent downgrade. Live tests against the real kernel: `aip-probe/tests/live_sensors.rs` (6), which capture a real write and real loopback TCP and assert that neither the file's content nor the wire payload appears anywhere in the serialized batch. The systemd unit trims capabilities per sensor and does **not** grant `CAP_SYS_ADMIN` by default

B8 No payload capture, ever — EXISTS

INSTRUMENT
DPDP data minimisation

DISPOSITION
EXISTS (invariant I23)

WHERE / ACCEPTANCE
`wiretap.rs` header-only decoder; grep-clean of payload capture

B9 Confidential probe→collector link — DONE

INSTRUMENT
IT Governance; DPDP

DISPOSITION
DONE

WHERE / ACCEPTANCE
`aip_transport::confidential`: a `Noise_NK_25519_ChaChaPoly_SHA256` session the authenticated protocol runs *inside*. The probe pins the collector's static public key; the collector's key is a third key, distinct from its evidence key and from any probe's transport-auth key, and a loaded key file is proven to be a pair before use. Both daemons use it unconditionally — there is no plaintext mode in either. **The acceptance test is a capture:** a tap on the probe's socket records the session, and the recording contains neither the probe id, nor its transport key in any encoding, nor a wire field name, nor the batch; a plaintext control finds all of them, which is what makes the negative result worth anything. A wrong pinned key fails the handshake before any authentication; a tampered message fails its tag and poisons the stream; a 4 MiB payload crosses ~65 messages intact; two sessions never share ciphertext. No `ring`, no TLS stack: `snow` on the curve25519/ChaCha20-Poly1305/SHA-256 primitives the workspace already carries

C. Reconciliation and verdicts (did execution match authority)

C1 Closed verdict vocabulary with `CANNOT_PROVE` default — EXISTS

INSTRUMENT
FREE-AI understanding by design

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-reconcile::ReconciliationResult`

C2 Evidence strength separated from severity; no self-report raises strength — EXISTS

INSTRUMENT
MRM explainability; FREE-AI

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`Draft::precondition_holds`; three-crate pins

C3 Verdicts name resources, not addresses — EXISTS

INSTRUMENT
RE audit usability

DISPOSITION
EXISTS (in the ledger)

WHERE / ACCEPTANCE
`aip-ledger` resolves every row against the cited `(registry_id, revision)`; verdicts themselves stay address-level by design (parameter digest unchanged)

C4 Per-agent, per-window access ledger: every resource reached, verdict, strength, signed, committed — EXISTS

INSTRUMENT
FREE-AI AI inventory; IT Governance; Digital Lending LSP accountability

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-ledger::AccessLedger` (signed by a fifth authority; `Standing` never above cited verdicts; unmatched verdicts counted); `LeafKind::AccessLedger` + `verify_committed_ledger` in `aip-nexora`; tests `aip-ledger/tests/ledger.rs` (10), `aip-nexora/tests/access_ledger.rs` (6, real-engine verdict)

C5 Verdicts stored and served by the RE's own service — EXISTS

INSTRUMENT
FREE-AI audit; RBI inspection

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`POST /v1/verdicts`, `GET /v1/verdicts/{id}`, `POST /v1/ledgers`, `GET /v1/agents/{id}/ledger`. Each document is **verified under the caller's anchors before it is stored** — the service must not be where a forged verdict acquires a bank's endpoint as its provenance — and returned verbatim, so an auditor re-verifies it offline with their own keys. The service adds no signature of its own. Tenant-scoped; a cross-tenant read is byte-identical to not-found. Tests: `aip-service/tests/verdict_api.rs` (8), including a round trip parsed back into `SignedReconciliation::verify` and `AccessLedger::verify`

C6 `PHANTOM_CLAIM` demonstrated on real hardware with the two-daemon pair — BUILD

INSTRUMENT
evidence honesty

DISPOSITION
BUILD (narrowed; still needs institution hardware and the decision point wired)

WHERE / ACCEPTANCE
What is now demonstrated: the two real daemons run end to end on a live kernel — `aip-probe` with four kernel sensors open, no key, over the authenticated and confidential transport to `aip-collector`, which holds the only key and signs. The **live foreign-eBPF gate attack** was executed against that pair and the collector signed `IntegrityUnknown` with attested coverage withdrawn, while the sequence advanced throughout (observer live, chain intact). Rows OI-13..OI-15 of `ADVERSARIAL_RESULTS.md`, raw output in `validation/pilot_e2e/results/sealed/`, reproducible by `validation/pilot_e2e/run.sh`. **What C6 still asks for and this does not give:** `PHANTOM_CLAIM` itself, which needs the

decision point issuing signed expectations into the same pipeline and the reconciler concluding an authorised action never executed — pilot Phases 2–3 — and all of it on a regulated entity's own hosts rather than a development VM

D. Evidence integrity, portability and verification

D1 Every artefact signed, domain-separated, canonically encoded

EXISTS

INSTRUMENT
non-repudiation

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-types::canonical`; Gate-13 distinct-domain test

D2 Append-only commitment with inclusion and consistency proofs

EXISTS

INSTRUMENT
IT Governance; CERT-In

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip-nexora` Merkle log, signed heads

D3 External anchoring of log heads

PARTIAL

INSTRUMENT
tamper evidence against the operator

DISPOSITION
DONE (mechanism) / INTEGRATE (placement)

WHERE / ACCEPTANCE
`aip-standalone/aip-anchor` and the `aip-anchor` command. A witness on a second system holds its own key, verifies each head under NEXORA anchors it was provisioned with, requires a consistency proof for every extension, and countersigns into a `WitnessReceipt` chained to its own previous receipt. An operator holding the NEXORA key can still sign a rewritten head — they cannot produce a receipt for it. `aip_anchor::audit` returns `Consistent`, `Diverged` (truncation, in-place rewrite, divergent history, or a log that declines to prove extension) or `NotEvaluated`, which is never a pass. **The placement is the entity's:** independence is an operational control the code cannot check, and `deploy/pilot/ANCHOR_WITNESS.md` states the four conditions, of which copying receipts outside the entity is the one that makes this evidence a third party can rely on

D4 Offline verification with RE-held keys, no call-home

EXISTS

INSTRUMENT
data residency; RBI inspection

DISPOSITION
EXISTS (all three evidence families)

WHERE / ACCEPTANCE
`aip-verify` (evidence packets), `nexora-verify` (log heads and proofs), and `aip-observe-verify` (the observer chain: attested batches and signed health). The third was the gap: the collector attested a batch, acknowledged it and **dropped it**, so the Phase 1 exit gate's "the verifier accepts it offline" had neither evidence on disk nor a tool to read it. The collector now appends every `AttestedBatch` to `attested.archive.jsonl` and publishes its evidence **public** key as `observer.pub` (previously obtainable only by unwrapping the private key with the passphrase). The verifier checks every signature, then the chain — contiguous sequences and `prev_head` against the **recomputed** head of the predecessor — and cross-checks health heads against the batch at the same position. Ledger rows EA-01..EA-10; run live as Phase D of `validation/pilot_e2e/run.sh`, with a negative control that must be refused

D5 Signed audit-export bundle for the auditor

EXISTS

INSTRUMENT
audit

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`/v1/evidence/{id}/export`; `verify_zip`

D6 Release artefacts signed, not only checksummed

EXISTS

INSTRUMENT
supply-chain assurance; MRM third-party

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
R12: keyless Sigstore signing in `release.yml`, with the release job verifying the signature it just produced under the same identity constraints a downloader uses, so a misconfiguration fails the release rather than shipping an unverifiable artefact. `VERIFYING.md` ships with the release. No long-lived signing key exists to leak. Note: the published key

D7 Storage-enforced immutability and retention (WORM, RLS, 180-day floor)

DONE

INSTRUMENT
CERT-In 180 days; IT Governance

DISPOSITION
DONE (controls + exercised restore)

WHERE / ACCEPTANCE
`deploy/sql/hardening.sql`, applied by the owning role: the service's role holds SELECT and INSERT only, and triggers make evidence append-only and enforce legal hold **against the owner too**. Row-level security scopes an unfiltered query and admits nothing to a connection that declared no tenant. Retention floor of 180 days is a CHECK, so a misconfigured policy is refused at write time. Proven against a real PostgreSQL: `aip-service/tests/storage_controls.rs` (10, `--ignored`). Durability is E5: `deploy/sql/restore_drill.sh` exercises a backup and restore and proves these controls survive it

E. Operations and incident handling

E1 Incident evidence bundle producible in minutes

DONE

INSTRUMENT
CERT-In 6 hours; FREE-AI incident form

DISPOSITION
DONE

WHERE / ACCEPTANCE
`aip-standalone/aip-incident` and its `aip-incident` command: `export --agent --from --to` assembles one signed bundle from already-signed documents (attested batches, verdicts, access ledgers, sensor health, expectations) and **computes the coverage it does not have**. Gaps are derived by subtracting the intervals the enclosed batches claim from the window asked for, they sit inside the manifest signature, and `verify` recomputes them independently. Reads only files — no collector or service call, so a network fault at the wrong moment cannot stop a filing. **Open:** the six-hour *reporting* path itself (who files, to whom, on which form) is the entity's, not the supplier's

E2 Metrics, SIEM export, runbook

DONE

INSTRUMENT
IT Governance; SOC

DISPOSITION
DONE

WHERE / ACCEPTANCE
`GET /metrics` on the service in Prometheus text format — authenticated, and **aggregate only**: no tenant, agent or document label, because a labelled series on a shared scrape is a cross-tenant disclosure channel. `aip-standalone/aip-siem` renders a verified verdict as CEF over RFC 5424 syslog. `deploy/pilot/RUNBOOK.md` is the on-call procedure, including the CERT-In six-hour assembly and the rule that `CANNOT_PROVE` is not a clean result. **Decision:** the Prometheus exposition format rather than the OpenTelemetry SDK — every stack named in the requirement scrapes it, including the OTel Collector, and it adds no dependency to a service whose metrics surface is ten counters

E3 Kill-switch trigger interface

PARTIAL

INSTRUMENT
MRM kill switch

DISPOSITION
EXISTS (tier) / **INTEGRATE** (trigger)

WHERE / ACCEPTANCE
Enforcement tier in tree: `aip-enforce` (seccomp user-notify execve gate deciding under a signed `CapabilityEpoch`; ADR-015) and `aip-interlock` (dead-man heartbeat, actuator watchdog, measured stopping budget). Both fail closed when the epoch or heartbeat lapses and neither reads observation or reconciliation. The *trigger* from a verdict to an epoch revocation is the RE's orchestration or SOAR; containment stays advisory in pilot.

E4 Clock discipline (NTP), time anchoring of evidence

PARTIAL

INSTRUMENT
CERT-In

DISPOSITION
DONE (control) / entity's (NTP sources)

WHERE / ACCEPTANCE
Two different questions, both answered. `BootClockAnchor` per batch relates the kernel and wall clocks so an event can be *placed* — it says nothing about whether the wall clock is right. `aip_observe::clock` asks the kernel the other question through `ntp_adjtime`: is a daemon steering this clock, and what is its error bound. `aip-collector` **refuses to start** when its own clock is unsynchronised or outside `AIP_COLLECTOR_CLOCK_MAX_ERROR_MS` (default 1000 ms), and reports the reading on every health cycle — because the collector stamps and signs everything, so an undisciplined clock there yields an archive that is wrong *together* and self-consistent, which nothing in the sealed bytes reveals. The override is explicit (`AIP_COLLECTOR_REQUIRE_SYNCED_CLOCK=0`) and a malformed value is refused rather than treated as off. `deploy/pilot/chrony-cert-in.conf` points at NIC/NPL. Tests: 7 in `aip-observe` including a live `ntp_adjtime` read; the gate was exercised end to end (refuses, overrides, rejects a bad value). **The reading is now inside the attested bytes** (protocol 12): `SensorHealth.clock` carries the synchronised flag, the kernel's error bound and the raw `ntp_adjtime` return code, so an offline verifier reading a sealed record can establish whether the clock producing its timestamps was being steered. It was previously operational only — checked, logged, and invisible to anyone holding the evidence. Editing, dropping or inserting the reading after signing each fails verification; a record with no reading is encoded distinctly from one with a good reading, so silence never reads as "fine"; the daemon reads the clock at its own boundary and hands it to the signer, which performs no syscalls on that path. `aip-observe-verify` prints the counts and the worst bound and judges none of it, because the acceptable bound is the institution's policy. Ledger rows CL-01..CL-09; tests: 9 in `aip-observe/tests/attested_clock.rs` plus 2 in `aip-observe-verify`. **Bounds, unchanged:** root on the collector host can call `adjtimex` itself and clear `STA_UNSYNC` on a clock it just moved (N1) — signing raises the bar from "trust the operator's log" to "the key signed this claim", and no further. Choosing and running the NTP sources remains the entity's

E5 Backup, DR, BCP for the evidence store

PARTIAL

INSTRUMENT
IT Governance BCP

DISPOSITION
DONE (drill) / entity's (RPO/RTO, off-site, cadence)

WHERE / ACCEPTANCE
`deploy/sql/restore_drill.sh`: an **exercised** restore against a real PostgreSQL. It dumps a hardened vault, restores into a separate empty cluster, and verifies both the evidence (byte-identical, verbatim signed bytes) **and that every control survived** — append-only trigger, legal hold, 180-day retention floor, least-privilege `aip_app` grant, and tenant row-level security all still enforced. The half a naive drill skips is exactly step 5. `docs/BACKUP_AND_RECOVERY.md` states what the entity sets: RPO/RTO, off-site and off-host custody, backup encryption and immutability, and the restore-drill cadence. Verified passing on Linux 6.18.44

E6 TLS and rate limiting at the service ingress

DONE

INSTRUMENT
IT Governance

DISPOSITION
DONE

WHERE / ACCEPTANCE
The split is by what each layer can see. **In-process** (`aip_service::ingress`, wired in `main`): a request body cap (`413` above `AIP_MAX_BODY_BYTES`, default 1 MiB), a per-request timeout (`408` above `AIP_REQUEST_TIMEOUT_SECS`, default 30 s), and a global in-flight cap (`AIP_MAX_IN_FLIGHT`, default 256). A malformed limit fails the start rather than disabling the control. **At the proxy** (`deploy/docker/reverse-proxy.conf`, referenced from compose): TLS termination, per-client rate and connection limits, and slow-loris timeouts — all needing the client's connection and address, which the service behind the proxy does not

have. Tests: `aip-service/tests/ingress_limits.rs` (4) and `ingress` unit tests (4), including that an oversized body is `413` with a key and that an unauthenticated giant body is refused without being read

E7 KMS/HSM custody for signing keys

PARTIAL

INSTRUMENT
IT Governance key management

DISPOSITION
DONE (mechanism) / entity's (module, PIN custody, ceremony)

WHERE / ACCEPTANCE
`aip-standalone/aip-hsm`: a PKCS#11 `Custodian`. The key is generated inside the module as `CKA_SENSITIVE`, non-extractable, and there is no import path. At open the custodian reads the policy back from the module and refuses an extractable or non-sensitive key, refuses two keys under one label, and proves the pair with a probe signature. The nonce comes from the module's RNG. The envelope is byte-identical to the software signer's, so no verifier changes. Tested against SoftHSM2 through the real PKCS#11 interface, including a second PIN-holding session asking for the private key and not getting it. CI installs SoftHSM2; the tests fail rather than skip without it. `deploy/pilot/HSM_CUSTODY.md` states what the entity decides: which module, who holds the PIN, key ceremony, and key backup (open, E5)

F. Governance artefacts the RE must hold

F1 AI inventory entry per agent, six-monthly review, inspectable

PARTIAL

INSTRUMENT
FREE-AI

DISPOSITION
EXISTS (the evidence attachment) + INTEGRATE (the entry itself)

WHERE / ACCEPTANCE
`aip_ledger::InventoryEntry::from_ledger` derives the attachment from a **verified** access ledger: which named resources the agent reached, ordered most-critical first, with rows counted by standing and `unproven`/`no_verdict` reported separately from `verified` so an unobserved window cannot read as a clean one. Cites the ledger by digest and the registry revision. Tests: `aip-ledger/tests/inventory.rs` (5). The inventory itself — owner, business purpose, model vendor, approval date — is the entity's and is not invented here

F2 Control-framework mapping (IT Governance, Outsourcing, Digital Lending, FREE-AI, MRM, CERT-In, DPDP) to code and tests

EXISTS

INSTRUMENT
all

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip_conformance::regulatory`: 25 rows over 7 instruments, emitted to `docs/compliance/CONTROL_MAP.{csv,json}`. A row claiming a control must name a file that exists, checked by test; a gap must be a sentence saying what would close it; no row may claim compliance, which is the entity's and its auditor's judgement. 3 stated gaps, 3 rows assigned to the entity. Tests: `aip-conformance/tests/control_map.rs` (7)

F3 Independent security assessment (CERT-In empanelled)

INTEGRATE

INSTRUMENT
CERT-In; segment regulator

DISPOSITION
INTEGRATE

WHERE / ACCEPTANCE
Commission it; R14's bundle and this matrix are its inputs

F4 Red teaming of the observer and the decision point, trigger-based

DONE

INSTRUMENT
FREE-AI

DISPOSITION
DONE

WHERE / ACCEPTANCE
`ADVERSARIAL_RESULTS.md` is the ledger; `validation/red_suite/` makes it reproducible by one command. `manifest.tsv` maps each of the 36 rows to the exact test that asserts its recorded outcome; `run.sh` runs them and reports `REPRODUCED`, `BLOCKED` (capability named), `NOTE` (a boundary) or `FAILED`, exiting non-zero on any `FAILED`. It is stricter than `cargo test`: a selector matching no test is a failure, not a vacuous pass, and that property is itself tested. On a host without `tracefs` the six live kernel-gate rows are `BLOCKED` and the off-host half of the same property (`OI-09`..`OI-12`) is reproduced; the CI job runs the suite so a regression in any claimed detection turns the build red

F5 Third-party model and vendor-agent accountability

EXISTS

INSTRUMENT
MRM; Outsourcing

DISPOSITION
EXISTS (evidence)

WHERE / ACCEPTANCE
Observation is external to the vendor process; INTEGRATE: contract clauses requiring the probe on vendor-operated hosts

F6 DPDP field-level review of every observed field

EXISTS

INSTRUMENT
DPDP

DISPOSITION
EXISTS

WHERE / ACCEPTANCE
`aip_conformance::dpdp`: 35 fields, each with what it holds, a personal-data risk class and why it is collected. The field set is **derived from the observation structure**, so a new field fails the build until it is documented; a test also asserts no field is classed as carrying personal data directly, which is the claim the pilot rests on. DPO sign-off template in `deploy/pilot/DPO_SIGNOFF_TEMPLATE.md`. Tests: `aip-conformance/tests/dpdp_inventory.rs` (5)

G. Out of scope — named owners

G1 Model bias, fairness, drift, data quality

INSTRUMENT
MRM; FREE-AI fairness

OWNER
Model risk function; model vendors

G2 Explainability of model decisions

INSTRUMENT
MRM

OWNER
Model vendors; RE model validation

G3 Customer disclosure, consent, grievance redress

INSTRUMENT
DPDP; Digital Lending; RBC

OWNER
RE compliance; consent managers

G4 Transaction-content fraud scoring, mule detection

INSTRUMENT
MuleHunter / IDPIC

OWNER
RBIH, IDPIC, RE fraud teams

G5 What was said inside a TLS session or a chat

INSTRUMENT
—

OWNER
Agent framework (sign tool calls, R4) and gateway receipts

G6 Root or kernel compromise of the observed host

INSTRUMENT
—

OWNER
Host hardening, hardware attestation (ADR-002), off-host observation research

G7 Concentration risk across vendors

INSTRUMENT
Governor's seven risks

OWNER
RE board; RBI supervision

G8 Performance, throughput, latency figures

INSTRUMENT
—

OWNER
Benchmark on institution hardware; none quoted until then

2. Roadmap (build items referenced above)

R1 Resource registry — done `aip-registry`**: signed, versioned registry of named resources (address ranges, ports, protocol, criticality class), canonical encoding, offline verification, endpoint→resource resolution with "unregistered" as an explicit outcome**

INSTRUMENT
—

ACCEPTANCE
Met: 22 tests

R2 Resource scope — done **Resource grants as `res:<id>` scope entries (signed, attenuating, no wire change); decision point resolves destinations against the verified registry and refuses unregistered or ungranted ones**

INSTRUMENT
R1

ACCEPTANCE
Met: 11 adversarial tests; the resolved name is deliberately kept out of the expectation's parameter digest

R3 Access ledger — done `aip-ledger`**: per-agent, per-window signed ledger of resources reached with verdict and strength, committed as `LeafKind::AccessLedger`, verifiable offline**

INSTRUMENT
R1

ACCEPTANCE
Met over the real-engine fixture: the verified connect becomes a named `Verified` row citing the reconciler's signed verdict; renames, drops, re-pointed revision, reordering and restated standing all refused

R4 Signed tool calls — done `ghost.tool.invoke.v1` action class (`tool_invoke_parameters`), gateway-countersigned `ToolReceipt`, `compare_tool_boundary` in `aip-airi` (extends AIRI's existing `ToolInvocation`; no second tool-call layer)

INSTRUMENT
R2

ACCEPTANCE
Met: a receipt for other parameters or another tool is `ReceiptDoesNotMatchAuthorization` whatever the agent claims; an agent misreport over a correct receipt is `ClaimDoesNotMatchAuthorization`; no receipt is `NotEvaluated`, never a finding; plaintext arguments appear in no signed document; the real reconciler yields `ACTION_EVIDENCE_UNAVAILABLE` for the class with a socket transition present. Not done: engine integration (gated) and NEXORA commitment of receipts (a twelfth leaf kind; wire change, batched with the next)

R5 Binding v2 — done (binding side) Namespace inodes and cgroup id in `ExecutionBinding`, version 2

INSTRUMENT
—

ACCEPTANCE
Met: two containers sharing a PID view, the same image and the same start tick are distinct executions; any one namespace differing separates them; a cgroup move does not; an absent identity on one side is `ContainerNotComparable`, never `DifferentContainer`; zeros are not an absence. **Carried into R8:** the same field on `ObservedProcess`, which is an observe-protocol wire bump

R6 Independent authority in the verifier — done `verify_packet` context flag refusing self-issued roots

INSTRUMENT
—

ACCEPTANCE
Met: self-issued root fails `AUTHORITY_CHAIN` when set, passes with an explicit note when not; a delegated packet passes under the same flag; relabelling the principal does not evade it; refusal is not tamper evidence

R7 Revocation distribution — done Signed, time-bounded revocation list for offline verifiers

INSTRUMENT
A6

ACCEPTANCE
Met: expired list → NOT EVALUATED with the reason printed, never a pass; fresh list cites issuer, sequence and validity; a list naming the packet's root token fails it; an unanchored list is not silently dropped; a list with no verification instant is refused at the command line

R8 Pilot probe sensors — done fanotify + AF_PACKET driven in `aip-probe`; per-sensor capability trim

INSTRUMENT
—

ACCEPTANCE
Met: 6 live tests against the real kernel (a captured write bound by pidfd, captured loopback TCP), the I23 no-content/no-payload assertions, gate-independence asserted, and fail-closed startup proven without needing any capability. The other half of B3 — `ObservedProcess` carrying container identity so the observer asserts it independently — landed separately as the protocol-11 bump; see row B3

R9 Confidential transport + ingress — done Noise NK on probe→collector; service ingress limits (body/timeout/in-flight) and a reference reverse-proxy config

INSTRUMENT
—

ACCEPTANCE
Transport: a captured session shows no plaintext metadata, with a plaintext control. Ingress: a body over the cap is `413` before the handler; an unauthenticated giant body is refused without being read; a malformed limit fails the start; TLS, per-client rate limiting and slow-loris timeouts are the proxy's, with a reference config

R10 Verdict API — done `aip-service` links the reconciler and the ledger; tenant-scoped verdict and ledger routes

INSTRUMENT
R3

ACCEPTANCE
Met: a verdict that does not verify is refused and nothing is filed; a submission with no anchors is refused; a stored verdict comes back and verifies offline under the caller's anchors; an agent's ledger likewise; a cross-tenant read is indistinguishable from not-found; every route is authenticated; re-filing one document is one row. Stored in PostgreSQL under the same `hardening.sql` grants and row policy as evidence, sharing one pool

R11 External anchoring — done (mechanism) Witness countersigns NEXORA heads with a key the log operator does not hold

INSTRUMENT
—

ACCEPTANCE
Met, and every rewrite test actually rewrites: a log rebuilt shorter and **signed with the real NEXORA key** passes every NEXORA check and is still caught as `Truncated`, naming how many records went; a same-size in-place rewrite is caught by root; a longer but different history fails the consistency check; a log that cannot prove extension is treated as divergent rather than unknown, so declining to prove is not an escape. A witness refuses to countersign an unverifiable head, a rollback, a fork, an unproven extension, or a head dated past its own clock; it refuses at construction to hold the log's own key or a mismatched keypair; a restart replays the receipt file, so a rollback cannot be slipped past one. A removed receipt breaks the chain. **Not covered by code:** that the witness is genuinely independent — `deploy/pilot/ANCHOR_WITNESS.md`

R12 Signed releases — done Keyless Sigstore signing in `release.yml`

INSTRUMENT
—

ACCEPTANCE
Met: the release job signs each archive and then verifies that signature with the same identity flags a downloader must use; `VERIFYING.md` ships alongside and states that omitting those flags accepts any Sigstore signature ever issued, which is not a check

R13 Storage controls — done (controls) RLS, no DELETE or UPDATE for the service role, retention floor, legal hold

INSTRUMENT
—

ACCEPTANCE
Met against a real PostgreSQL: the service role's DELETE, UPDATE, TRUNCATE, DROP and `DISABLE ROW LEVEL SECURITY` are all refused by the database; an unfiltered SELECT returns only the declared tenant; an undeclared connection sees nothing; a held packet resists the owner; a 90-day retention policy is refused by the CHECK. **Open:** backup/DR and the restore drill (E5)

R14 Incident bundle — done `aip-incident export` / `verify` / `summary`

INSTRUMENT
R3

ACCEPTANCE
Met: a hole between two attested batches is stated with its bounds and its length at export time and again at verification; a window with no batches reads as wholly uncovered rather than as complete; a document removed, altered or added after signing is detected; a bundle re-signed with an erased gap fails recomputation, which is the defence that survives an exporter key in the wrong hands; the bundle identifier is derived from the contents so an export can be reproduced; a malformed invocation writes no bundle at all

R15 Metrics/SIEM/runbook — done Prometheus metrics, CEF/syslog verdict export, runbook

INSTRUMENT
R10

ACCEPTANCE
Met: a verdict that does not verify under the caller's anchors produces **no** SIEM event, so the console is not where a forgery acquires the institution's provenance; a tampered verdict likewise; `CANNOT_PROVE` renders as the absence of evidence in words and does not route beside `VERIFIED_EXECUTION`; the exporter adds no judgement of its own beyond the severity CEF makes mandatory, which is a fixed total table of the result class alone and provably independent of evidence strength; a hostile reconciler identifier — signed, so a valid verdict can carry one — is **refused** rather than logged ambiguously, and the refusal names the verdict digest; `/metrics` is unauthenticated to nobody, carries no label, and counts a refused verdict that is by definition invisible in the store. 35 tests in `aip-siem`, 4 over the service's real router

R16 HSM custodian — done (mechanism) **PKCS#11** `Custodian`, `aip-hsm` **CLI (**`provision`, `public-key`, `self-test`**)**

INSTRUMENT
—

ACCEPTANCE
Met, against a real token: the module refuses to return the private key to a session holding the PIN; an extractable key, a non-sensitive key, a duplicate label, a wrong PIN, a missing token and a mislabelled pair are each refused at open with a named error; the envelope verifies under `aip_crypto::verify_ed25519` and `ReconcilerSigner` signs a verdict through the module; signing from several threads is serialised and every signature verifies; a second custodian on a token already logged into opens, and the consequence — its PIN is not re-checked — is stated; key generation is serialised in-process and the commissioning rule for the cross-process case is written down. 27 tests. **Not covered by code:** module certification, PIN custody, ceremony, key backup

R17 Inventory export — done **FREE-AI inventory shape**

INSTRUMENT
R3

ACCEPTANCE
Met: derived only from a verified ledger, so an unsigned or tampered one yields no entry; an unobserved window is not reported as verified; resources ordered most-critical first; the ledger cited by digest

R18 Control map — done **control ID → code → test → artefact**

INSTRUMENT
all

ACCEPTANCE
Met: every claimed control names a file that exists (checked); every gap states what would close it; the three items open elsewhere in this matrix read as gaps here too, by test, so the two documents cannot drift apart with the control map becoming the more flattering one

R19 RED suite harness — done `validation/red_suite/` **(manifest + runner + CI job)**

INSTRUMENT
—

ACCEPTANCE
Met: one command reproduces every ledger row it can on the host, names the capability for every row it cannot, and fails if a claimed detection no longer holds. on a privileged host with tracefs: 33 reproduced or runnable, 2 `NOTE`, 1 `deferred` (`OI-08`); in a capability-free environment the kernel rows report `BLOCKED` with the reason instead; the vacuous-pass trap is closed and tested

R20 DPDP field inventory — done **every batch field, lawful basis, DPO template**

INSTRUMENT
—

ACCEPTANCE
Met: the inventory is checked against the structure it describes, so it cannot fall behind the code; every row states a purpose, not a label; zero fields carry personal data directly, asserted by test. DPO sign-off is the entity's to complete before Phase 1

Reading this matrix

Lead with the EXISTS rows and their tests. Show the BUILD rows with their

acceptance tests as commitments with dates, not as features. Show the OUT OF

SCOPE table unprompted: an evaluator who finds it before you say it will

assume the rest of the matrix is equally optimistic. The INTEGRATE rows are

where the RE's own teams and the RE's vendors must act; name them in the

pilot's roles section.